

DevSecOps Agent (Agent 3)

Deep Technical Specification & Operational Manual

Executive Overview & Purpose

The DevSecOps Agent provides comprehensive Static Application Security Testing (SAST), secret detection, Dockerfile container audits, and Infrastructure-as-Code (IaC) Terraform auditing across enterprise software repositories.

1. Architectural Overview & Workflow

- Position in LangGraph Engine: Primary analysis node for Pipeline A (DevSecOps Pipeline) and Pipeline A_THEN_B.
- Repository Ingestion: Supports direct code input as well as asynchronous cloning of public/private GitHub repositories (git clone).
- State Propagation: Populates state.code_audit_report and appends SAST findings to state.findings.

2. Local High-Precision Secret Detection

- Pre-LLM Regex Scanning: Scans raw source files for credentials before submitting code to external models.
- Pattern Library: Detects AWS Access Key IDs (AKIA...), GitHub Tokens (ghp_...), JWT Tokens, Bearer Tokens, and Private Keys.
- Redaction Guarantee: Masking algorithm shows only the first 4 and last 4 characters (e.g., AKIA****EXAMPLEKEY) to prevent credential leakage.

3. Container & Infrastructure-as-Code Audits

- Dockerfile Auditing: Identifies root container execution (USER root), unpinned base images (ubuntu:latest), and exposed build-arg credentials.
- Terraform IaC Auditing: Identifies overly permissive security group ingress rules (0.0.0.0/0), public S3 bucket ACLs, and unencrypted EBS volumes.

4. Code Refactoring & Remediation Advice

- Vulnerable Snippets: Extracts exact file paths and line numbers where vulnerabilities reside.
- Secure Fix Snippets: Generates drop-in, refactored code snippets implementing parameterized SQL queries, sanitized inputs, and secure environment variable access.